Intern privacy- en informatiebeveiligingsbeleid

Cliëntgegevens, personeelsgegevens en digitale werkplek

PROFESSIONALS

Versienummer: 1.1
Versiedatum: 5 augustus 2026
Documenteigenaar: Directie / privacyverantwoordelijke

Documenteigenaar	Directie / privacyverantwoordelijke
Versie	1.1 vastgesteld
Datum	5 augustus 2026
Classificatie	Intern gebruik
Herziening	Jaarlijks en na relevante wets- of systeemwijzigingen
Goedkeuring	Jeroen Buuts en Paul Spijker 24-08-2026

Inhoud

1. Doel, reikwijdte en uitgangspunten....4
2. Juridisch en normatief kader....5
3. Rollen en verantwoordelijkheden....6
3.1 Beoordeling verplichting FG....6
4. Verwerking van cliëntgegevens....8
4.1 Wmo-begeleiding....8
4.2 Wlz-begeleiding....8
4.3 Forensische begeleiding....8
4.4 Behandeling en diagnostiek....8
4.5 Scheiding en samenloop van zorgvormen....8
5. Digitale werkplek en veilige communicatie....10
5.1 E-mail en berichtenverkeer....10
5.2 Gedragscode digitale werkplek....10
6. Technische en organisatorische beveiliging....12
7. Bewaartermijnen en vernietiging....14
8. Rechten van cliënten, medewerkers en andere betrokkenen....17
9. Datalekken en beveiligingsincidenten....18
10. Verwerkers, verwerkingsregister en DPIA....19
10.1 Verwerkers en leveranciers....19
10.2 Verwerkingsregister....19
10.3 DPIA....19
11. Bewustwording, kennis en geheimhouding....20
12. Controle, evaluatie en naleving....21
13. Interne escalatie- en beslismatrix....22
14. Toegangsmatrix informatie, mappen en dossiers....23
14.1 Uitgangspunten....24
14.2. Toegangsmatrix....25
14.3 Beheersing en periodieke controle....27
15. Contactgegevens....28
Bijlage A: Beoordeling FG op basis van artikel 37 AVG....29

1. Doel, reikwijdte en uitgangspunten

Dit beleid beschrijft hoe PJ Professionals persoonsgegevens rechtmatig, behoorlijk, transparant en veilig verwerkt bij Wmo-begeleiding, Wlz-begeleiding, forensische begeleiding, behandeling en diagnostiek. Het geldt voor directie, werknemers, stagiairs, ingehuurde professionals, vrijwilligers en andere personen die namens de organisatie toegang hebben tot persoonsgegevens of informatiesystemen.

Het beleid geldt voor cliëntgegevens, gezondheidsgegevens, diagnostische gegevens, Wmo- en Wlz-gegevens, forensische en strafrechtelijke gegevens, personeelsgegevens en gegevens van sollicitanten, leveranciers en samenwerkingspartners, ongeacht of deze digitaal, op papier, mondeling, via e-mail of in een extern systeem worden verwerkt.

Kernregel: verwerk alleen persoonsgegevens die noodzakelijk zijn voor een vooraf bepaald en gerechtvaardigd doel, geef uitsluitend toegang op basis van functie en noodzaak, en bewaar gegevens niet langer dan toegestaan of noodzakelijk.

2. Juridisch en normatief kader

- Algemene verordening gegevensbescherming (AVG), waaronder de beginselen van artikel 5, de beveiligingsplicht van artikel 32, de rechten van betrokkenen en de verantwoordingsplicht.
- Uitvoeringswet AVG (UAVG).
- Wet op de geneeskundige behandelingsovereenkomst (WGBO), voor zover sprake is van een geneeskundige behandelingsovereenkomst.
- Wet maatschappelijke ondersteuning 2015 (Wmo 2015), voor zover persoonsgegevens in het kader van Wmo-begeleiding worden verwerkt.
- Wet aanvullende bepalingen verwerking persoonsgegevens in de zorg (Wabvpz) en het Besluit elektronische gegevensverwerking door zorgaanbieders, voor zover van toepassing.
- NEN 7510, NEN 7512 en NEN 7513, voor zover deze normen op de organisatie, gebruikte systemen of gegevensuitwisseling van toepassing zijn.
- Wet langdurige zorg (Wlz), de Wet forensische zorg (Wfz), toepasselijke regels voor justitiële en strafvorderlijke gegevens, en fiscale, arbeidsrechtelijke en overige specifieke bewaarplichten.

Op grond van artikel 3, tweede lid, van het Besluit elektronische gegevensverwerking door zorgaanbieders draagt een zorgaanbieder overeenkomstig NEN 7510 en NEN 7512 zorg voor veilig en zorgvuldig gebruik van het zorginformatiesysteem en van het elektronische uitwisselingssysteem waarop hij is aangesloten.

3. Rollen en verantwoordelijkheden

Rol	Verantwoordelijkheid	Minimale taak
Directie	Eindverantwoordelijk voor privacy en informatiebeveiliging.	Beleid vaststellen, middelen beschikbaar stellen, risico's beoordelen en besluiten over meldingen en maatregelen.
Privacyverantwoordelijke	Coördineert AVG-naleving en adviseert de directie.	Verwerkingsregister, verzoeken van betrokkenen, datalekregister, DPIA-beoordelingen, bewustwording en periodieke controles.
		Informeren, adviseren, toezicht houden en contactpunt voor de Autoriteit Persoonsgegevens
ICT-beheerder / Levix/ Edsas	Voert overeengekomen technische beheer- en beveiligingstaken uit.	Accounts, autorisaties, logging, firewall, updates, back-ups, endpointbeveiliging, incidentondersteuning
Leidinggevenden	Borgen naleving in de teams.	Autorisaties aanvragen en intrekken, medewerkers instrueren en controleren, incidenten escaleren
Medewerkers	Handelen zorgvuldig en melden afwijkingen direct.	Clean desk, schermvergrendeling, veilige communicatie, geheimhouding, minimale gegevensverwerking en direct melden van incidenten.

3.1 Beoordeling verplichting FG

De organisatie beoordeelt en documenteert periodiek of een FG verplicht is op grond van artikel 37 AVG. De beoordeling omvat ten minste: de kerntaken, het aantal betrokkenen, de hoeveelheid en gevoeligheid van gegevens, de duur en structurele aard van de verwerking en de geografische reikwijdte. Op basis van de huidige feiten en omstandigheden is de organisatie van oordeel dat de verwerking van bijzondere en strafrechtelijke persoonsgegevens niet

kwalificeert als grootschalige verwerking als bedoeld in artikel 37 AVG. Deze beoordeling wordt periodiek geëvalueerd en zo nodig aangepast aan gewijzigde omstandigheden of nieuwe jurisprudentie en richtsnoeren. De onderbouwde FG-beoordeling wordt als apart besluit bewaard en jaarlijks herzien, zie hiervoor Bijlage A.

4. Verwerking van cliëntgegevens

4.1 Wmo-begeleiding

Bij Wmo-begeleiding wordt een ondersteunings- of begeleidingsdossier bijgehouden. Dit bevat alleen gegevens die noodzakelijk zijn voor de uitvoering en evaluatie van de ondersteuning, de rapportage aan de opdrachtgever, de veiligheid en de wettelijke verantwoording. De WGBO is niet van toepassing indien er sprake is van uitsluitend maatschappelijke begeleiding.

4.2 Wlz-begeleiding

Bij Wlz-begeleiding wordt een cliënt- of zorgdossier bijgehouden dat aansluit op de indicatie, het zorgplan, doelen, voortgang, risico's, evaluaties en afspraken met cliënt, vertegenwoordiger en ketenpartners. De WGBO is niet van toepassing indien er sprake is van uitsluitend maatschappelijke begeleiding.

4.3 Forensische begeleiding

Bij forensische begeleiding kunnen naast gezondheidsgegevens ook strafrechtelijke en justitiële gegevens worden verwerkt, zoals de strafrechtelijke titel, voorwaarden, aanwezigheid, medewerking, behandeltrouw en informatie die noodzakelijk is voor toezicht, risicobeheersing, recidivebeperking en verantwoording. Deze gegevens worden strikt doelgebonden verwerkt en uitsluitend gedeeld met bevoegde partijen wanneer daarvoor een wettelijke, contractuele of professioneel noodzakelijke grondslag bestaat.

4.4 Behandeling en diagnostiek

Voor behandeling en diagnostiek wordt een behandel- en diagnostiekdossier bijgehouden. Hierin worden uitsluitend gegevens opgenomen die noodzakelijk zijn voor een goede uitvoering van de diagnostiek en behandeling, waaronder de hulpvraag, onderzoeksbevindingen, testresultaten, professionele conclusies, het behandelplan, voortgangsrapportages, evaluaties en relevante correspondentie.

Voor zover de behandeling en diagnostiek plaatsvinden op basis van een geneeskundige behandelingsovereenkomst, zijn op dit dossier de bepalingen van de Wet op de geneeskundige behandelingsovereenkomst (WGBO) van toepassing, waaronder de wettelijke regels over dossiervorming, bewaartermijnen, inzage, correctie en vernietiging.

Voor cliënten die uitsluitend maatschappelijke begeleiding ontvangen, is de WGBO in beginsel niet van toepassing. Op deze dossiers zijn de AVG en de voor de betreffende zorgvorm geldende wettelijke en contractuele verplichtingen van toepassing.

4.5 Scheiding en samenloop van zorgvormen

Wanneer een cliënt meerdere zorgvormen ontvangt, wordt in het dossier duidelijk gemaakt vanuit welke opdracht, financiering en professionele rol gegevens zijn vastgelegd. Medewerkers voorkomen dat Wmo-, Wlz-, forensische, behandel- en diagnostische gegevens zonder noodzaak door elkaar worden gebruikt of gedeeld. Toegang wordt zo ingericht dat medewerkers alleen de gegevens zien die zij voor hun taak nodig hebben.

- PJ Professionals hanteert als hoofdterm het cliëntdossier. Binnen dit dossier wordt herkenbaar vastgelegd of gegevens betrekking hebben op Wmo-begeleiding, Wlz-begeleiding, forensische begeleiding, behandeling of diagnostiek. Cliëntgegevens worden uitsluitend vastgelegd in het aangewezen cliënt- of zorginformatiesysteem, bijvoorbeeld ECD/EDC. Losse notities, privéapparaten, persoonlijke mailboxen, onbeheerde spreadsheets en niet-goedgekeurde cloudopslag zijn niet toegestaan.
- Gezondheidsgegevens, diagnostische gegevens, BSN, strafrechtelijke gegevens en andere bijzondere of wettelijk beschermde gegevens worden alleen verwerkt wanneer daarvoor een geldige grondslag en wettelijke uitzondering bestaat. Per zorgvorm wordt uitsluitend vastgelegd wat noodzakelijk is voor de begeleiding, behandeling, diagnostiek, verantwoording, veiligheid en wettelijke of contractuele verplichtingen.
- Bij intake of aanmelding worden niet méér gegevens gevraagd dan noodzakelijk. Gegevens die nog niet nodig zijn, worden niet “voor de zekerheid” verzameld.
- Een identiteitsdocument wordt uitsluitend ingezien en de noodzakelijke controle wordt vastgelegd.
- Toegang tot dossiers is functiegebonden, persoonlijk en gebaseerd op need-to-know. Medewerkers raadplegen uitsluitend dossiers waarbij zij beroepsmatig betrokken zijn.
- Logging van dossierinzage en wijzigingen wordt ingericht en periodiek gecontroleerd. Ongebruikelijke raadplegingen worden onderzocht en vastgelegd.

5. Digitale werkplek en veilige communicatie

5.1 E-mail en berichtenverkeer

- Persoonlijke gezondheidsinformatie wordt alleen via een door de organisatie goedgekeurde, passende beveiligde of versleutelde communicatievoorziening verzonden. Gewone e-mail wordt daarvoor niet gebruikt, tenzij de beveiliging aantoonbaar passend is ingericht.
- Controleer vóór verzending de ontvanger, bijlagen, zichtbare geadresseerden en het noodzakelijke detailniveau. Gebruik BCC waar meerdere externe ontvangers elkaars adres niet mogen zien.
- Verstuur geen volledig dossier wanneer een gerichte selectie volstaat. Gebruik waar mogelijk een beveiligd portaal of veilige-mailoplossing.
- Verzend wachtwoorden of toegangscodes niet via hetzelfde kanaal als het beveiligde bestand.
- Meld verkeerd verzonden e-mail of bijlagen onmiddellijk als mogelijk datalek.

5.2 Gedragscode digitale werkplek

- **Clean desk en clean screen:** laat geen dossiers, lijsten, notities of beeldschermen met vertrouwelijke informatie onbeheerd zichtbaar achter. Berg papieren stukken afgesloten op.
- **Scherm vergrendelen:** vergrendel het scherm bij iedere afwezigheid, ook kortdurend.
- **Beveiliging van telefoon en tablet:** beveilig iedere telefoon of tablet waarop zakelijke informatie, e-mail of cliëntinformatie toegankelijk is met een pincode en/of biometrische beveiliging, zoals vingerafdruk of gezichtsherkenning.
- **Extra beveiliging van zakelijke e-mail op telefoon:** gebruik waar mogelijk aanvullende beveiliging voor toegang tot zakelijke e-mail, bijvoorbeeld een aparte pincode, biometrische toegang en multifactorauthenticatie (MFA).
- **Meldingen op vergrendelscherm:** voorkom waar mogelijk dat de inhoud van zakelijke e-mails, berichten of andere vertrouwelijke informatie zichtbaar is op het vergrendelscherm van telefoon of tablet.
- **Persoonlijke inlogmiddelen:** gebruikersnamen, wachtwoorden, tokens en MFA-middelen zijn persoonlijk en worden nooit gedeeld. Gebruik een wachtwoordmanager wanneer die door de organisatie is goedgekeurd.
- **Signal als voorkeurskanaal:** gebruik voor interne communicatie met vertrouwelijke of cliëntgerelateerde informatie bij voorkeur Signal in plaats van WhatsApp. Gebruik Signal, voor zover passend en praktisch uitvoerbaar, ook zoveel mogelijk in het contact met cliënten.
- **Beperk cliëntinformatie in berichtenapps:** deel via berichtenapps niet meer cliëntinformatie dan noodzakelijk. Uitgebreide cliëntinformatie en inhoudelijke verslaglegging horen in het ECD en niet uitsluitend in een berichtenapp.
- **Cliëntinformatie zoveel mogelijk in het ECD:** sla cliëntinformatie zoveel mogelijk op in het daarvoor bestemde ECD. Voorkom structurele opslag van cliëntgegevens in persoonlijke mappen, op het bureaublad, in Downloads of in losse Word- of Excelbestanden.

- **Geen parallel cliëntdossier:** voorkom dat naast het ECD een tweede of onvolledig cliëntdossier ontstaat in persoonlijke mappen, mailboxen, berichtenapps of andere systemen. Het ECD is zoveel mogelijk de centrale en actuele plaats voor cliëntinformatie.
- **Tijdelijke bestanden:** wanneer het voor de uitvoering van werkzaamheden noodzakelijk is om tijdelijk een bestand met cliëntinformatie buiten het ECD op te slaan of te bewerken, verwijder deze tijdelijke kopie zodra deze niet meer nodig is en zorg dat relevante informatie in het ECD is vastgelegd.
- **E-mail is geen dossier:** gebruik de mailbox niet als structurele opslagplaats voor cliëntinformatie. Leg relevante informatie uit e-mail, wanneer deze onderdeel uitmaakt van het cliëntdossier, vast in het ECD volgens de interne werkwijze en verwijder mails uit je mailbox.
- **Vertrouwelijke gesprekken:** bespreek cliëntinformatie alleen op een plaats waar onbevoegden niet kunnen meeluisteren. Beperk namen en herkenbare details en anonimiseer of pseudonimiseer waar mogelijk.
- **Goedgekeurde middelen:** gebruik uitsluitend goedgekeurde apparatuur, software, opslagmedia en verbindingen. Privé-USB-sticks en onbeheerde apparaten zijn niet toegestaan voor de verwerking van cliënt-, personeels- of andere vertrouwelijke gegevens.
- **Geen privéopslag:** sla zakelijke of cliëntgebonden informatie niet op in privé-e-mail, privécloudopslag, persoonlijke notitieapps of andere niet-goedgekeurde diensten.
- **Printen:** print alleen wanneer noodzakelijk. Haal documenten direct op en laat vertrouwelijke afdrukken niet onbeheerd bij de printer liggen.
- **Vernietigen van papieren:** vernietig vertrouwelijke papieren via de daarvoor bestemde afgesloten voorziening voor vertrouwelijk afval.
- **Foto's en schermafbeeldingen:** maak geen foto's of schermafbeeldingen van cliëntinformatie, behalve binnen een goedgekeurd werkproces en systeem.
- **Updates en beveiliging:** installeer beveiligingsupdates op zakelijke apparatuur tijdig en schakel beveiligingsvoorzieningen niet uit.
- **Verlies of diefstal:** meld verlies of diefstal van een telefoon, laptop, toegangsmiddel of ander apparaat waarmee zakelijke informatie toegankelijk is direct volgens de interne procedure.
- **Verkeerd verzonden informatie:** meld het direct telefonisch bij de privacyverantwoordelijke, teamleider of directie wanneer vertrouwelijke informatie naar een verkeerde ontvanger is verzonden, een verkeerde bijlage is meegestuurd of wanneer mogelijk sprake is van onbevoegde toegang. Zie de procedure datalek hiervoor.
- **Controleer ontvangers en bijlagen:** controleer vóór verzending van vertrouwelijke informatie altijd de ontvanger(s), cc/bcc-velden en bijlagen.
- **Minimale gegevensverwerking:** raadpleeg, gebruik, verstuur en bewaar alleen persoonsgegevens die noodzakelijk zijn voor de uitvoering van de werkzaamheden.

6. Technische en organisatorische beveiliging

Onderwerp	Maatregel	Uitvoerder	Controle / bewijs
Accounts en autorisaties	Unieke accounts, MFA zoals bij MS365 en Nedap, rolgebaseerde toegang, herbeoordeling bij veranderingen.	Leidinggevende + ICT/Levix	Autorisatielijst
Uitdiensttreding	Toegang uiterlijk op het moment van uitdiensttreding blokkeren; bedrijfsmiddelen innemen.	HR/leidinggevende + ICT/Levix	Offboardingchecklist en afsluitbevestiging.
Logging	Loggen van toegang en relevante handelingen; steekproeven en onderzoek bij signalen.	ICT/Levix + privacyverantwoordelijke	Lograpportage, bevindingen en opvolging.
Firewall en netwerk	Beheerde firewall, veilige configuratie, segmentatie waar nodig en herbeoordeling bij veranderingen.	ICT/Levix/ Edsas	Beheer- of servicerapportage.
Updates en kwetsbaarheden	Tijdige beveiligingsupdates, antivirus/EDR, ondersteunde software en kwetsbaarheidsopvolging.	ICT/Levix	Patchrapportage en incidenttickets.
Back-up en herstel	Versleutelde back-ups, beperkte toegang en periodieke hersteltest.	ICT/Levix	Hersteltest en back-uprapportage.

Onderwerp	Maatregel	Uitvoerder	Controle / bewijs
Apparatuur	Schijfversleuteling, schermvergrendeling, remote wipe waar passend en inventarisatie.	ICT/Levix	Assetregister en configuratiecontrole.
Leveranciers	Voorafgaande privacy- en securitybeoordeling, passende contracten en periodieke evaluatie.	Directie + privacyverantwoordelijke	Leveranciersdossier, overeenkomst, evaluatie.

7. Bewaartermijnen en vernietiging

De organisatie hanteert per verwerking een vastgelegde bewaartermijn. De termijn begint op het wettelijk of beleidsmatig bepaalde moment. Na afloop worden gegevens veilig verwijderd, geanonimiseerd of vernietigd, tenzij een aantoonbare wettelijke plicht, lopende procedure of zwaarwegend gerechtvaardigd belang langere bewaring vereist.

Gegevenscategorie	Hoofdtermijn	Startmoment / nuance	Grondslag
Behandel- en diagnostiekdossier waarop WGBO van toepassing is	20 jaar	Vanaf de laatste wijziging in het dossier; langer indien goed hulpverlenerschap dit redelijkerwijs vereist. Dit geldt alleen voor het deel waarop de WGBO van toepassing is.	Art. 7:454 lid 3 BW.
Wmo-begeleidingsdossier	15 jaar	Vanaf de laatste vastgelegde wijziging; langer indien noodzakelijk voor zorgvuldige uitvoering. Een vernietigingsverzoek kan tot eerdere vernietiging leiden, behoudens wettelijke uitzonderingen.	Art. 5.3.4 en 5.3.5 Wmo 2015.
Wlz-begeleidingsdossier	Volgens vastgestelde bewaarmatrix	De Wlz kent voor ambulante begeleiding niet zonder meer één algemene dossiertermijn zoals de Wmo. De termijn wordt bepaald op basis van de aard van de zorg, toepasselijke zorgwetgeving, contractuele eisen, verantwoording en noodzaak. Als de WGBO van toepassing is op behandeling, geldt voor dat deel 20	AVG-opslagbeperking; Wlz en toepasselijke zorgwetgeving/contracten.

Gegevenscategorie	Hoofdtermijn	Startmoment / nuance	Grondslag
		jaar.	
Forensisch begeleidingsdossier	Volgens vastgestelde bewaarmatrix en toepasselijke ketenafspraken	Termijn wordt per gegevenssoort vastgesteld, rekening houdend met de Wet forensische zorg, justitiële ketenverplichtingen, behandel- of begeleidingsovereenkomst, toezicht, declaratie, claims en eventuele WGBO-toepasselijkheid. Niet langer bewaren dan noodzakelijk.	Wfz, AVG/UAVG, toepasselijke contract- en ketenregels; zo nodig WGBO.
Diagnostische ruwe data en testmateriaal	Volgens professionele standaard en bewaarmatrix	Bewaar niet langer dan nodig voor verantwoorde diagnostiek, herbeoordeling en wettelijke of professionele verplichtingen.	AVG, eventuele WGBO en toepasselijke beroeps- of teststandaarden.
Personeelsdossier – algemene stukken	In beginsel maximaal 2 jaar na uitdiensttreding	Alleen voor stukken zonder afwijkende wettelijke termijn en voor zover niet langer noodzakelijk voor een geschil of rechtsvordering.	AVG-beginsel opslagbeperking; AP-richtsnoer.
Loonadministratie en fiscaal relevante gegevens	Volgens toepasselijke fiscale bewaarplicht van 7 jaar.	Niet onder de algemene termijn van 2 jaar.	Fiscale wetgeving.
Sollicitatiegegevens	In beginsel 4 weken na einde procedure	Langer bewaren alleen met geldige grondslag en transparante informatie, doorgaans met toestemming.	AVG-opslagbeperking en AP-richtsnoer.

Gegevenscategorie	Hoofdtermijn	Startmoment / nuance	Grondslag
Datalek- en incidentregistratie	Zolang noodzakelijk voor verantwoording, leren en eventuele claims	Termijn risicogestuurd vaststellen in bewaarmatrix; toegang strikt beperken.	Art. 33 lid 5 AVG en verantwoordingsplicht.
Logging	Volgens toepasselijke norm, wet, risico en systeemdoel	Termijn per systeem vastleggen; niet onbeperkt bewaren.	NEN 7513 / toepasselijke regelgeving en AVG.

8. Rechten van cliënten, medewerkers en andere betrokkenen

Betrokkenen kunnen onder meer verzoeken om inzage, rectificatie, verwijdering, beperking, overdraagbaarheid of bezwaar. Voor cliëntdossiers binnen Wmo-begeleiding, Wlz-begeleiding, forensische zorg, behandeling en diagnostiek kunnen daarnaast specifieke wettelijke, professionele en contractuele regels gelden.

1. Het verzoek wordt direct doorgestuurd aan de privacyverantwoordelijke en geregistreerd met ontvangstdatum, soort verzoek en uiterste beslisdatum.
2. De identiteit wordt proportioneel gecontroleerd. Er wordt niet standaard een volledige kopie van een identiteitsbewijs gevraagd of bewaard.
3. De privacyverantwoordelijke bepaalt welke wettelijke regeling van toepassing is en betrekt zo nodig directie, dossierverantwoordelijke, behandelaar/begeleider, jurist of FG.
4. Op een AVG-verzoek wordt zonder onredelijke vertraging en in beginsel binnen één maand gereageerd. Een eventuele verlenging wordt binnen die eerste maand gemotiveerd meegedeeld.
5. Inzage of afschrift wordt veilig verstrekt. Bij digitale verstrekking wordt een beveiligd kanaal gebruikt. Voorkeur voor fysieke afgifte daarbij wordt de legitimatie gecontroleerd en ontvangst vastgelegd.
6. Rectificaties worden doorgevoerd waar gegevens feitelijk onjuist of onvolledig zijn. Professionele oordelen worden niet zonder grond gewijzigd; een aanvullende verklaring kan aan het dossier worden toegevoegd.
7. Bij afwijzing of gedeeltelijke uitvoering ontvangt de verzoeker een gemotiveerde beslissing met informatie over klacht- en rechtsmogelijkheden.
8. Het verzoek, de beoordeling, de uitgevoerde handelingen en het antwoord worden bewaard zolang dat noodzakelijk is om naleving aan te tonen, zonder méér persoonsgegevens te bewaren dan nodig.

Voor het behandel- en diagnostiekdossier waarop de WGBO van toepassing is, gelden onder meer het inzage- en afschriftrecht van artikel 7:456 BW en het vernietigingsrecht van artikel 7:455 BW. Voor Wmo-gegevens geldt onder meer artikel 5.3.5 Wmo 2015. Voor Wlz- en forensische dossiers wordt per verzoek beoordeeld welke bijzondere wettelijke, professionele of contractuele regeling naast de AVG van toepassing is. Het recht op rectificatie volgt uit artikel 16 AVG.

9. Datalekken en beveiligingsincidenten

- Iedere medewerker meldt een mogelijk datalek of beveiligingsincident direct via het interne meldkanaal aan de privacyverantwoordelijke en leidinggevende. Bij spoed wordt tevens de directie en ICT/Levix ingeschakeld.
- De melding bevat voor zover bekend: wat is gebeurd, wanneer, welke systemen en gegevens zijn betrokken, hoeveel personen mogelijk zijn geraakt, wie toegang had en welke directe maatregelen zijn genomen. Voor het afhandelen van een datalek is een apart formulier en protocol ontwikkeld.
- De organisatie stopt of beperkt het incident, bewaart relevant bewijs en beoordeelt het risico voor betrokkenen.
- Indien meldplichtig wordt het datalek zo mogelijk binnen 72 uur na kennisneming gemeld aan de Autoriteit Persoonsgegevens. Bij een hoog risico worden betrokkenen onverwijld geïnformeerd, tenzij een wettelijke uitzondering geldt.
- Alle datalekken, ook niet-gemelde, worden in het datalekregister opgenomen met feiten, gevolgen, maatregelen en motivering van de meldbeslissing.
- Na ieder relevant incident volgt een evaluatie van oorzaken, maatregelen en structurele verbeteringen.

10. Verwerkers, verwerkingsregister en DPIA

10.1 Verwerkers en leveranciers

Met iedere partij die persoonsgegevens uitsluitend in opdracht van de organisatie verwerkt, wordt vóór de verwerking een verwerkersovereenkomst gesloten die voldoet aan artikel 28 AVG. De organisatie beoordeelt daarnaast beveiliging, subverwerkers, datalocatie, ondersteuning bij verzoeken en incidenten, verwijdering na einde contract en controleerbaarheid.

10.2 Verwerkingsregister

De privacyverantwoordelijke houdt een actueel register van verwerkingsactiviteiten bij. Het register bevat ten minste doeleinden, categorieën betrokkenen en gegevens, ontvangers, eventuele doorgiften buiten de EER, bewaartermijnen en een algemene beschrijving van beveiligingsmaatregelen. Ook structurele verwerkingen van personeelsgegevens worden opgenomen.

10.3 DPIA

Voor een nieuwe of wezenlijk gewijzigde verwerking wordt vooraf beoordeeld of deze een risico oplevert. Een DPIA is in ieder geval aangewezen bij grootschalige verwerking van bijzondere persoonsgegevens, stelselmatige monitoring, innovatieve technologie met aanzienlijke privacygevolgen of andere situaties op de toepasselijke DPIA-lijst. Zonder afgeronde risicoafweging en noodzakelijke maatregelen wordt de verwerking niet gestart.

11. Bewustwording, kennis en geheimhouding

- Nieuwe medewerkers ontvangen vóór of direct bij toegang tot systemen instructie over privacy, informatiebeveiliging, datalekken, veilig mailen, dossierinzage en de digitale werkplek.
- Medewerkers zijn getraind en hebben geoefend met praktijksimulaties. Deelname wordt geregistreerd.
- Iedereen met toegang tot persoonsgegevens is gebonden aan een passende geheimhoudingsverplichting.
- Onzekerheid over delen, bewaren, mailen of verwijderen wordt vóór de handeling voorgelegd aan de privacyverantwoordelijke.
- Overtredingen kunnen leiden tot intrekking van toegang, aanvullende instructie, arbeidsrechtelijke maatregelen of melding aan bevoegde instanties, afhankelijk van ernst en omstandigheden.

12. Controle, evaluatie en naleving

- Jaarlijkse controle van actieve accounts, rollen en uitdiensttredingen.
- Periodieke, risicogestuurde controle van dossierlogging en ongebruikelijke raadplegingen.
- Jaarlijkse controle van verwerkingsregister, bewaarmatrix, leveranciers, FG-beoordeling, incidenten en verbetermaatregelen.
- Voorafgaande privacy- en securitytoets bij nieuwe systemen, koppelingen, apps, AI-toepassingen of gegevensuitwisselingen.
- In de jaarlijkse managementrapportage worden de bevindingen, risico's, incidenten, verzoeken, training en opvolging opgenomen.

13. Interne escalatie- en beslismatrix

Situatie	Direct betrekken	Beslisser	Vastlegging
Privacyverzoek	Privacyverantwoordelijke + dossier-/procesverantwoordelijke	Directie bij complexe weigering; FG adviseert indien aanwezig	Verzoekenregister en besluit.
Mogelijk datalek	Privacyverantwoordelijke, directie, ICT/Levix	Directie/ verwerkingsverantwoordelijke	Datalekregister, risicoanalyse, meldbesluit.
Nieuwe leverancier of systeem	Proceseigenaar, privacyverantwoordelijke, ICT/Levix	Directie	Risicotoets, contract, verwerkersovereenkomst, DPIA-besluit.
Ongebruikelijke dossierinzage	Privacyverantwoordelijke, leidinggevende, ICT/Levix	Directie/HR afhankelijk van uitkomst	Onderzoeksdossier met beperkte toegang.
Uitdiensttreding	HR/leidinggevende en ICT/Levix	Leidinggevende	Offboardingchecklist en afsluitbevestiging.

14. Toegangsmatrix informatie, mappen en dossiers

Met deze toegangsmatrix is vastgelegd welke rollen toegang hebben tot algemene, bestuurlijke, cliëntgebonden en personeelsinformatie, wie informatie mag wijzigen of verwijderen en welke aanvullende controle geldt. De autorisaties combineren daarmee beschikbaarheid voor het werk met beperking van toegang tot vertrouwelijke informatie.

14.1 Uitgangspunten

Feit: De autorisaties zijn functiegericht ingericht: toegang en bewerkrechten worden bepaald door de rol en de noodzaak voor het werk.

Feit: Voor cliëntdossiers geldt een aanvullende escalatie wanneer iemand niet aan de cliënt is gekoppeld. De gebruiker moet dan aangeven waarom toegang noodzakelijk is.

Feit: De privacyverantwoordelijke controleert de escalatieoverzichten ieder kwartaal.

14.2. Toegangsmatrix

Map / dossier	Wie heeft toegang	Rechten	Beheersmaatregel / toelichting
Medewerkersmap – algemeen	Alle medewerkers, management/teamleiders, directie, staf en beleidsmedewerker	Lezen + bewerken	Algemene samenwerkingsomgeving.
Medewerkersmap – Formulieren	Alle medewerkers	Alleen lezen	Bewerkrechten zijn beperkt om vastgestelde formulieren tegen onbedoelde wijzigingen te beschermen.
Medewerkersmap – Formulieren	Directie, management/teamleiders, administratie en beleidsmedewerker	Lezen + bewerken + verwijderen	Meerdere functies kunnen formulieren onderhouden; dit vermindert de afhankelijkheid van één persoon en borgt continuïteit bij afwezigheid van de beleidsmedewerker.
Medewerkersmap – Beleid	Alle medewerkers	Alleen lezen	Vastgesteld beleid blijft voor iedereen beschikbaar zonder algemeen wijzigingsrecht.
Medewerkersmap – Beleid	Directie, management/teamleiders, Administratie en beleidsmedewerker	Lezen + bewerken + verwijderen	Bewerkrechten zijn functiegericht beperkt.
Notulen in medewerkersmap	Alle medewerkers	Lezen + bewerken	Deze notulen vallen onder de algemene medewerkersmap en zijn voor iedereen toegankelijk.
KMS – algemeen	Administratie, beleidsmedewerker, management/teamleiders en directie	Lezen + bewerken + verwijderen	Niet toegankelijk voor overige medewerkers.
Notulen in KMS	Administratie, beleidsmedewerker, management/teamleiders en directie	Lezen + bewerken + verwijderen	Afgeschermde notulen binnen het KMS.
Eigen persoonlijke map	Iedere medewerker: uitsluitend eigen map	Lezen + bewerken + verwijderen	Geen algemene toegang tot persoonlijke mappen van anderen.
Directiemap	Directie	Lezen + bewerken + verwijderen	Uitsluitend toegankelijk voor directie.
Cliëntendossier – gekoppelde cliënt	Medewerkers die functioneel aan de cliënt zijn gekoppeld; overige functies alleen voor zover functioneel noodzakelijk	Lezen + bewerken conform rol	Toegang volgt de betrokkenheid bij de cliënt en het need-to-know-principe.
Cliëntendossier – niet gekoppelde cliënt	Geautoriseerde gebruiker na escalatie	Toegang na motivering	Gebruiker motiveert waarom toegang noodzakelijk is. Deze escalaties worden geregistreerd.
Escalatieoverzichten cliëntdossiers	Privacyverantwoordelijke	Controleren	Controle vindt ieder kwartaal plaats.
Cliëntendossiers – verwijderen	Administratie	Verwijderen	Verwijderrecht ligt bij financiële administratie/staf. Inhoudelijke toegang blijft beperkt tot wat functioneel noodzakelijk en geautoriseerd is.

Map / dossier	Wie heeft toegang	Rechten	Beheersmaatregel / toelichting
Personeelsdossiers	Directie en administratie	Lezen + bewerken + verwijderen	Toegang is beperkt tot directie en staf.

14.3 Beheersing en periodieke controle

- **Autorisaties:** Autorisaties worden gekoppeld aan functies en aangepast bij functiewijziging, in- of uitdiensttreding en andere relevante wijzigingen.
- **Cliëntdossiers:** Toegang tot een niet-gekoppeld cliëntdossier wordt alleen via de ingerichte escalatie gebruikt en voorzien van een motivering.
- **Controle escalaties:** De privacyverantwoordelijke beoordeelt de escalatieoverzichten ieder kwartaal op noodzaak en opvallende of ongebruikelijke toegang.
- **Verwijderen:** Verwijderrechten voor cliënt- en personeelsdossiers liggen bij administratie. Dit recht staat los van bredere inhoudelijke toegang: inhoudelijke toegang blijft functie- en noodzaakgebonden.
- **Formulieren en beleid:** Algemene medewerkers hebben alleen leesrecht; directie, management/teamleiders, administatie en beleidsmedewerker hebben bewerkrecht. Daarmee worden zowel documentintegriteit als continuïteit geborgd.

15. Contactgegevens

De privacyverantwoordelijke binnen PJ Professionals zijn:

Lisette Bogaerts en Brenda van Middelkoop

E-mail: info@pjprofessionals.nl

(Vermoedelijke) privacy-incidenten en datalekken worden onmiddellijk telefonisch gemeld aan:

De privacyverantwoordelijke; de directie of de leidinggevende.

Aanvullende informatie over een privacy-incident of datalek wordt verzonden naar:

info@pjprofessionals.nl

Voor het verzenden van bijzondere persoonsgegevens en andere vertrouwelijke informatie per e-mail wordt gebruikgemaakt van E-mailadres: beveiligdmailen@pjprofessionals.nl.

Contactpersoon Levix: Melissa van Schijndel. Indien er problemen zijn m.b.t. ICT en middelen zal via Melissa contact worden gelegd met Levix. Raadpleeg eerst Melissa alvorens contact te leggen met Levix.

Accountmanagement Levix

Voor advies, offertes en ICT-vraagstukken.
073 - 303 06 11
sales@levix.nl

Support Levix

Voor technische vragen, ondersteuning en storingen.
073 - 303 06 06
support@levix.nl

Administratie & algemene vragen

073 - 534 11 31
receptie@levix.nl

Bijlage A: Beoordeling FG op basis van artikel 37 AVG

PJ Professionals heeft beoordeeld of de organisatie op grond van artikel 37 van de Algemene Verordening Gegevensbescherming (AVG) verplicht is een Functionaris Gegevensbescherming (FG) aan te wijzen.

Bij deze beoordeling zijn de wettelijke criteria uit artikel 37 AVG betrokken, evenals de richtsnoeren van de European Data Protection Board (EDPB) over de aanwijzing van een FG. Daarbij is onder meer gekeken naar:

- de aard van de verwerkte persoonsgegevens;
- de omvang van de verwerkingen;
- het aantal betrokkenen;
- de duur en structurele aard van de verwerkingen;
- de kernactiviteiten van de organisatie.

Afweging

PJ Professionals verleent begeleiding binnen de Wet maatschappelijke ondersteuning (Wmo) en de Wet langdurige zorg (Wlz). Daarnaast biedt de organisatie begeleiding, behandeling en diagnostiek binnen de forensische zorg.

De kernactiviteit van PJ Professionals bestaat uit het bieden van begeleiding. Voor deze begeleiding worden persoonsgegevens verwerkt die noodzakelijk zijn voor een verantwoorde uitvoering van de ondersteuning.

Binnen het elektronisch cliëntendossier (ECD) worden, voor zover noodzakelijk voor de begeleiding, ook gezondheidsgegevens vastgelegd, zoals relevante diagnoses, medicatie of lopende behandeling. Deze gegevens worden uitsluitend verwerkt wanneer zij noodzakelijk zijn voor de kwaliteit en veiligheid van de begeleiding.

Binnen de forensische zorg worden daarnaast strafrechtelijke persoonsgegevens verwerkt, waaronder informatie over het delict, risicobeoordelingen en andere gegevens die noodzakelijk zijn voor de uitvoering van de forensische opdracht. Deze verwerking betreft een beperkt deel van de cliëntenpopulatie.

PJ Professionals begeleidt circa 250 cliënten, waarvan ongeveer 30 cliënten binnen de forensische zorg vallen. De organisatie telt ongeveer 25 medewerkers. Op basis van de huidige omvang van de organisatie en de aard van de verwerkingen is beoordeeld dat de verwerking van bijzondere persoonsgegevens en strafrechtelijke persoonsgegevens naar verwachting niet als grootschalige verwerking in de zin van artikel 37 AVG kan worden aangemerkt.

Op grond van deze beoordeling concludeert PJ Professionals dat op dit moment geen eenduidige wettelijke verplichting bestaat tot het aanwijzen van een Functionaris Gegevensbescherming. Deze beoordeling wordt periodiek herzien en opnieuw uitgevoerd wanneer de omvang van de organisatie, de aard van de dienstverlening of de gegevensverwerking wijzigt.

Privacyfunctie

Hoewel de organisatie op dit moment geen formeel aangewezen Functionaris Gegevensbescherming heeft, acht PJ Professionals een onafhankelijke privacyfunctie van groot belang.

Binnen de organisatie is één medewerker opgeleid tot Functionaris Gegevensbescherming. Daarnaast volgt een tweede medewerker de opleiding tot Functionaris Gegevensbescherming. Door afwezigheid wegens verlof is de formele invulling van deze functie tijdelijk uitgesteld.

PJ Professionals heeft de intentie om uiterlijk in 2027 de privacyfunctie verder te formaliseren en de functie van Functionaris Gegevensbescherming of een daarmee gelijkwaardige onafhankelijke privacyfunctie structureel te beleggen. Bij deze keuze wordt opnieuw beoordeeld of de organisatie op grond van de AVG verplicht is een FG aan te wijzen dan wel of een vrijwillige aanwijzing passend is.

Tot het moment waarop de functie formeel is ingevuld, worden de privacytaken uitgevoerd door de directie, ondersteund door medewerkers met specifieke deskundigheid op het gebied van privacy en gegevensbescherming. De organisatie blijft daarmee zorgdragen voor naleving van de AVG, de bescherming van persoonsgegevens en het continu verbeteren van haar privacybeleid.